# Compte-rendu d’incident et retour d’expérience

**Participer à la détection et au traitement d’un incident de sécurité, de sa qualification jusqu’au retour d’expérience.**

Olivier HIMBLOT • Formation AIS • Travail individuel
Laboratoire File Browser / Suricata / Wazuh
Activités du 9 octobre 2026 — Analyse et REX du 12 octobre 2026

## Synthèse pour le formateur

La reproduction contrôlée depuis l’hôte montre deux scans, puis **22 GET HTTP 200** vers File Browser. Suricata produit **99 alertes de volume SYN**. Les chemins inhabituels et leur répétition sont visibles, sans alerte HTTP correspondante dans l’extrait analysé.

**Qualification : reconnaissance et exploration HTTP établies pour la reproduction ; compromission non démontrée.** L’essai initial sur la VM demeure partiellement documenté. Les propositions de traitement privilégient conservation, observation et vérification ciblée ; aucune coupure automatique n’est justifiée par les pièces.

## Correspondance avec les critères

| Critère | Preuve présentée |
|---|---|
| Distingue faits et hypothèses | Statuts et limites explicites, page 4. |
| Reconstitue une chronologie | Chronologie consolidée, page 3. |
| Qualifie la situation | Conclusion circonstanciée, pages 1 et 4. |
| Propose un traitement proportionné | Décisions, impacts et vérifications, page 5. |
| Tire les enseignements | Comparaison avec le script et améliorations, pages 6–7. |

Pièces illustrées : sortie du scénario, alertes Suricata et recherches sans résultat, pages 8–10. Les captures ne remplacent pas les sorties complètes utilisées pour les comptages.

# 1. Signalement, périmètre et sources

**Signalement :** « Plusieurs accès à des pages ou ressources inattendues ont été observés sur le service File Browser. » La borne 13:20 est un choix de recherche, pas un début d'activité démontré.

| Élément | Périmètre documenté |
|---|---|
| Hôte / capteur | 192.168.122.1 ; Suricata sur virbr0. |
| VM / service | 192.168.122.229 ; File Browser exposé en HTTP sur 8080, Docker 8080 → 80. |
| Wazuh | Manager 192.168.122.37 ; agent 001 vm-filebrowser sur la VM. |
| Séquences séparées | Invocations initiales VM ; navigation Firefox 14:06 ; reproduction hôte 14:33–14:35. |

| Source | Apport | Limite |
|---|---|---|
| Suricata EVE | Origine, destination, URI, codes HTTP, SID et action. | Extraits sans corps HTTP ; capture initiale locale incomplète. |
| Terminal, Nmap, curl | Début/fin, états de ports et réponses client. | Nom Nmap de service ≠ version identifiée ; dernière boucle sans codes affichés. |
| Journald / auditd | Invocations sudo, sessions, PackageKit. | Pas preuve de chaque GET ni de toutes les phases du script. |
| Archives Wazuh | Réception et contexte système agent 001. | Copie des logs locaux ; heure de réception distincte. |
| Docker / recherches | Fenêtres et résultats sans message retrouvés. | Silence ≠ absence de requêtes ou panne de Wazuh. |
| Script / routes | Phases prévues et trajet local relevé. | Code ≠ exécution ; route actuelle ≠ capture historique. |

## Référence du scénario

Copie fournie : **j9-filebrowser-incident.sh**, attribuée au formateur par Olivier. Le REX compare cette copie déjà transmise aux preuves ; aucune nouvelle variante ni trace complète de l'exécution du formateur n'a été fournie à cette étape.

SHA-256 de la copie examinée :
e185f5da52fbab1f6327803046b78736b769a18a78b3fee49d8938ebe731689d

# 2. Chronologie consolidée

9 octobre 2026, **CEST (UTC+02:00)**. Compléments journald/auditd lus le 12 octobre. Confiance élevée pour les faits cités, limitée pour leurs effets non observés.

| Heure | Source | Fait observé / portée |
|---|---|---|
| 13:58:05–06 | Journald | Session SSH oliv depuis l'hôte, puis déconnexion ; lien au script non établi. |
| 13:59:59.576 | Journald | Script invoqué sans argument, contexte fermé immédiatement. |
| 14:00:14–14:01:17 | Journald/auditd | Essai vers la propre adresse VM ; phases non établies. |
| 14:01:27–56 | Journald/dpkg/Wazuh | apt update, installation Nmap ; préparation administrative. |
| 14:01:59.367–14:04:28.275 | Journald/auditd/Wazuh | Nouvelle invocation VM vers elle-même, PID 159232 ; fin de contexte. |
| 14:06:18–31 | Suricata HTTP | Dix requêtes Firefox depuis l'hôte ; navigation distincte du script. |
| 14:06:58.250–253 | Journald/auditd | Arrêt PackageKit identifié ; pas arrêt File Browser. |
| 14:33:13 | Terminal hôte | Début reproduction vers VM:8080. |
| Phase de scan | Nmap | Six ports : 22/8080 ouverts ; quatre fermés. Scan 1–1000 : 22 ouvert, 999 fermés. |
| 14:33:35.132–.138 | Suricata alert | 99 alertes SID 1009001, action allowed ; volume SYN. |
| 14:34:05.149 / 10.158 | Suricata/curl | Deux GET /, réponses 200. |
| 14:34:30.168–51.228 | Suricata/curl | Huit chemins inhabituels, tous 200, environ 3 s d'intervalle. |
| 14:35:14.245–36.343 | Suricata HTTP | Douze GET /admin, tous 200, environ 2 s d'intervalle. |
| 14:35:38 | Terminal | Fin affichée ; 22 GET EVE au total. |
| Recherches après activité | Docker/Wazuh/auditd | Aucun résultat sur les fenêtres montrées ; activité réseau néanmoins prouvée. |

Heures des deux scans à compléter par les flows. Wazuh reçoit l'invocation à 14:01:59.967 et la fin à 14:04:29.817 : la différence avec le journal local n'établit pas une anomalie d'horloge.

# 3. Faits, hypothèses et qualification

| Conclusion | Éléments | Statut |
|---|---|---|
| Reproduction depuis hôte vers VM | Terminal et champs EVE 192.168.122.1 → 192.168.122.229. | Établie |
| Exploration et répétition | Nmap + 22 GET : 2 racine, 8 chemins, 12 /admin. | Établie |
| Alerte de volume SYN | 99 objets SID 1009001, action allowed. | Établie |
| HTTP 200 = réponse reçue | Statuts curl et EVE. | Établie |
| Angle mort initial lié à lo | Invocation locale, route lo relevée ; capteur virbr0. | Probable |
| 200 = page de repli | Comportement compatible, corps non conservés. | Hypothèse |
| Fichiers sensibles réellement lus | URI /.env, /config.json etc. sans corps. | Non démontrée |
| Exploitation / accès non autorisé | Pas d'effet d'exploitation ni contexte d'autorisation probant. | Non démontrés |
| Modification / persistance / exfiltration | Pas d'écriture qualifiée, mécanisme ou transfert sensible établi. | Non démontrés |
| Indisponibilité File Browser | Arrêt identifié PackageKit, pas impact mesuré sur File Browser. | Non démontrée |

## Chemins concernés

/admin, /backup, /private, /config, /config.json, /.env, /debug, /old. Tous ont répondu 200 dans la reproduction ; **13 demandes /admin** au total. URI demandée ≠ ressource réelle, réponse 200 ≠ contenu divulgué.

## Informations manquantes

Sortie complète de l'essai initial ; corps/routage des réponses ; identité et droits applicatifs ; état avant/après des données ; détail des refus réseau ; couverture et rétention des logs. L'absence absolue d'exploitation ou de conséquence n'est pas certifiée.

## Qualification retenue

**Reconnaissance et exploration HTTP démontrées dans une reproduction pédagogique.** Le script n'inclut pas de phase explicite d'exploitation ou de persistance. Il ne prouve pas, à lui seul, l'absence d'effets côté serveur. L'incident initial reste à qualification provisoire ; aucune compromission n'est établie.

# 4. Traitement proportionné et remédiations

**Décision ≠ exécution.** La documentation et les lectures historiques sont réalisées ; les mesures ci-dessous demeurent proposées sauf indication explicite.

| Action / délai | Justification | Impact | Vérification |
|---|---|---|---|
| Conserver événements — immédiat | Préserver pièces avant rotation ; captures intégrées, exports originaux à compléter. | Stockage et accès aux preuves ; faible impact service. | Provenance, fenêtre, lisibilité ; empreintes si réalisées. |
| Observer / lire sources — immédiat | Préciser hypothèses sans rejouer le passé. | Charge disque/CPU limitée ; garder état actuel distinct. | Source, filtre, période et résultat consignés. |
| Compléter flows — immédiat si disponibles | Qualifier refus et ordre précis des scans. | Lecture ciblée ; ne pas perdre les rotations. | flow.start, ports, source, flow_id. |
| Adapter règles — différé | Couverture HTTP inadéquate et bruit SYN. | Faux positifs, coût, rechargement à encadrer. | Syntaxe, SID distinct, positifs/négatifs, référence normale. |
| Vérifier logs applicatifs — prochaine investigation | Expliquer absence des GET dans Docker/Wazuh. | Volume et données sensibles à maîtriser. | Test distinct : requête → log → collecte → recherche. |
| Mise à jour / remplacement — différé | Maintenance et risques de cycle de vie, sans exploitation prouvée. | Compatibilité, interruption, sauvegarde. | Version/digest, restauration, tests fonctionnels. |
| Limiter / bloquer / isoler / arrêter — conditionnel | Non justifiés actuellement ; réévaluer sur menace ou impact établi. | Service/admin interrompus ; perte d’état et visibilité. | Décideur, périmètre, accès légitimes et retour arrière. |

## Déclencheurs de réévaluation

Accès réellement non autorisé, contenu sensible exposé, exploitation/persistance étayée ou dégradation mesurée : réexaminer une mesure ciblée en conservant les pièces accessibles et en consignant pertes de visibilité et impact sur le service.

## Actions effectivement documentées

Lectures historiques, intégration de sorties/captures, chronologie, qualification et décisions. **Aucune nouvelle règle, restriction, mise à jour, isolation ou interruption n’est exécutée pour produire ce rapport.** Aucun export intégral des journaux n’est déclaré réalisé.

# 5. REX : comparaison au script fourni

Le script prévoit deux scans puis 22 GET, avec 143 s de pauses. La reproduction dure 145 s. Code et effets observés sont comparés séparément ; l'essai initial VM ne devient pas intégralement prouvé par ce rapprochement.

| Activité | Détectée / interprétée | Source | Écart / cause |
|---|---|---|---|
| Six ports puis 1–1000 | Scans client établis ; volume SYN alerté. Interprétation : reconnaissance, pas compromission. | Nmap, EVE | 99 alertes ≠ 99 scans ; premier/second scan à isoler par flows. |
| Ports fermés | Client : quatre puis 999 fermés ; détail réseau incomplet. | Nmap | SID 1009002 cible 65001–65003, hors scénario. Règle inadaptée. |
| Deux GET / | Deux HTTP 200 ; usage du service correctement qualifié. | Curl, HTTP EVE | SID 1008002 exige cinq GET / en 10 s ; pas seuil atteint. |
| Huit chemins atypiques | Huit 200 ; exploration observée sans divulgation prouvée. | Curl, HTTP EVE | SID 1009003 vise /ais-lab-inhabituel-, hors chemins du script. |
| Douze GET /admin | Douze 200 à ~2 s ; répétition retrouvée, sans alerte HTTP correspondante. | HTTP EVE | Règle sur /, pas /admin ; codes non affichés par dernière boucle. |
| Essai VM vers elle-même | Invocation prouvée, phases non confirmées. | Journald/audit d/Wazuh | Trajet local probable hors virbr0 : point d'observation. |
| GET dans Docker/Wazuh | Recherches vides, interprétées comme limite et pas absence d'activité. | Docker, archives | Journalisation/collecte des succès non établie : information absente. |

## Interprétations corrigées ou pistes écartées

Horaire approximatif 14:06 précisé par invocation locale 14:01:59. Firefox reste distinct (login/polices, pas le curl du script). Arrêt de service identifié comme PackageKit. 13:20 reste une borne de recherche. HTTP 200 ne confirme ni fichier lu ni page de repli ; scans/exploration ne confirment ni exploitation ni persistance.

Le script ne prévoit pas de POST /api/renew ou de ports 65001–65003. Ces anciens tests de capacité sont exclus de la chronologie de reproduction. Sa ligne de fin n'atteste pas la réussite de toutes les commandes ; les preuves EVE/client sont nécessaires.

# 6. Améliorations et gouvernance

| Amélioration | Cause ciblée | Contrôle attendu |
|---|---|---|
| Définir injection et trajet ; compléter capteur local si besoin | Point d’observation | Route/interface et événement témoin ; séparer nouvelles preuves du passé. |
| Couvrir exploration et répétition HTTP selon service | Règles absentes/inadaptées | Positifs et navigation normale ; garder ancien jeu, date et SID. |
| Corréler refus/volume et regrouper alertes SYN | Bruit et détail manquant | Flows/ports/horaires ; mesurer avant ajustement. |
| Tracer versions, hash, début/fin, fuseaux, retours | Corrélation et information | Identifiant de test, heure activité/réception et provenance. |
| Accès applicatifs et conservation ciblée | Information absente | Chaîne de collecte testée, rétention et droits définis. |

## File Browser : version et exposition

Le dossier historique décrit 2.15.0 puis une migration vers 2.63.23. Ne pas confondre version ancienne et version au moment du scénario sans preuve datée. Publication Docker IPv4/IPv6 et accès HTTP depuis l’hôte établis ; exposition Internet non démontrée. Vérifier filtrage au point effectif, dont trajet Docker, depuis sources autorisées et interdites.

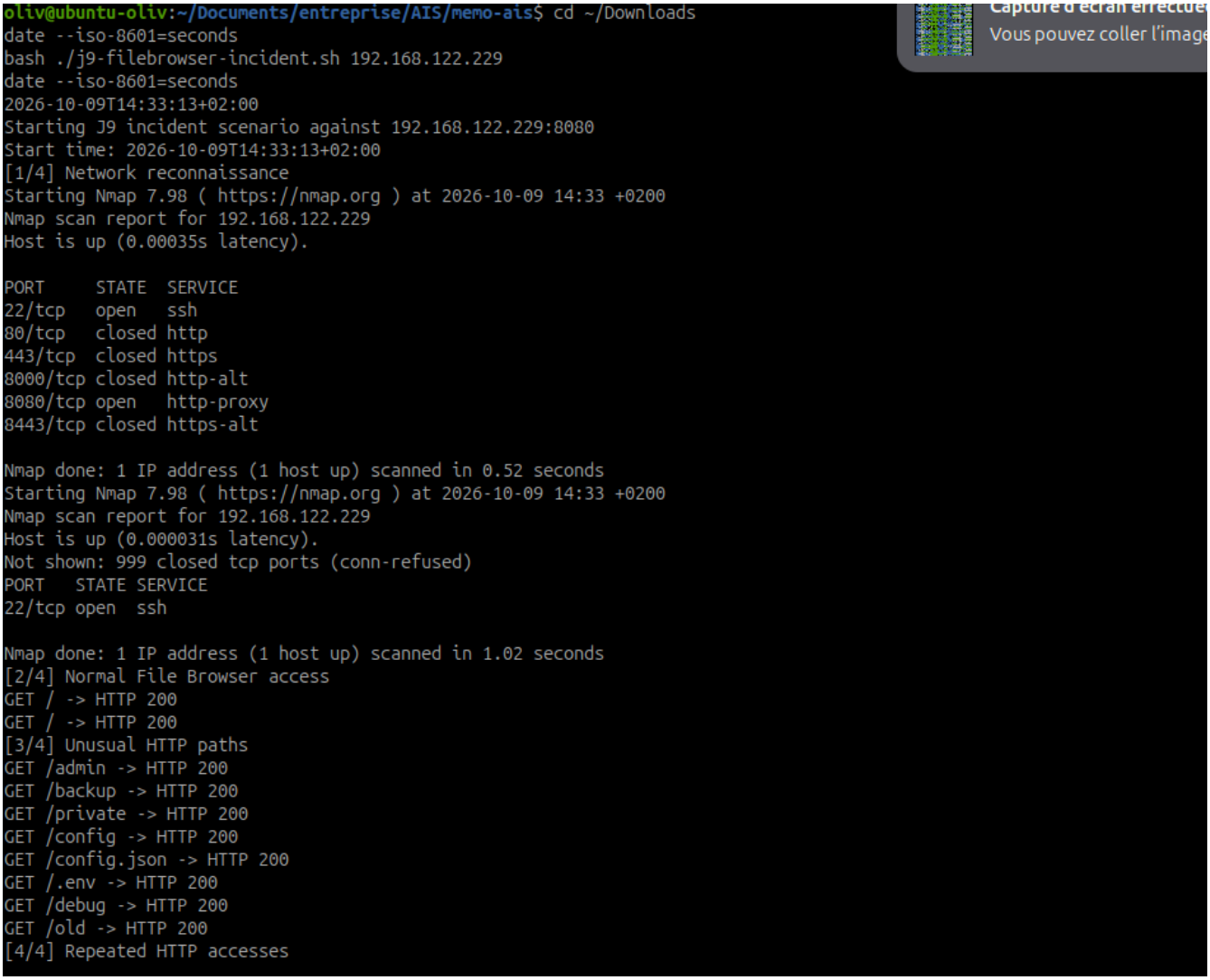
Le dépôt officiel est archivé et annonce l’arrêt des nouvelles versions et corrections de sécurité (contrôle documentaire du 12 octobre 2026). Une mise à niveau ne rétablit pas la maintenance. Les limites de commandes et sessions signalées par l’éditeur doivent être qualifiées selon configuration, sans les présenter comme exploitées ici.

Sources : dépôt officiel File Browser ; avis de sécurité officiels.

| Responsabilité à désigner | Action organisationnelle / preuve |
|---|---|
| Propriétaire du service | Finalité, données, utilisateurs, exposition ; décision de maintien temporaire datée ou remplacement avec échéance. |
| Administrateur | Inventaire version/digest/OS, maintenance, sauvegarde/restauration et migration testée ; droits/exposition contrôlés. |
| Référent sécurité | Veille avis et dépendances, applicabilité, risques résiduels et délais ; conservation et procédure d’escalade. |
| Responsable supervision | Matrice activité/source/règle/tests ; couverture et bruit revus après chaque changement. |

Rôles proposés, non adoption d’une politique d’entreprise. Dans le laboratoire, travail individuel d’Olivier et consignes/scénario du formateur. Priorité organisationnelle : plan de sortie du logiciel non maintenu avec continuité de service et responsabilités explicites.

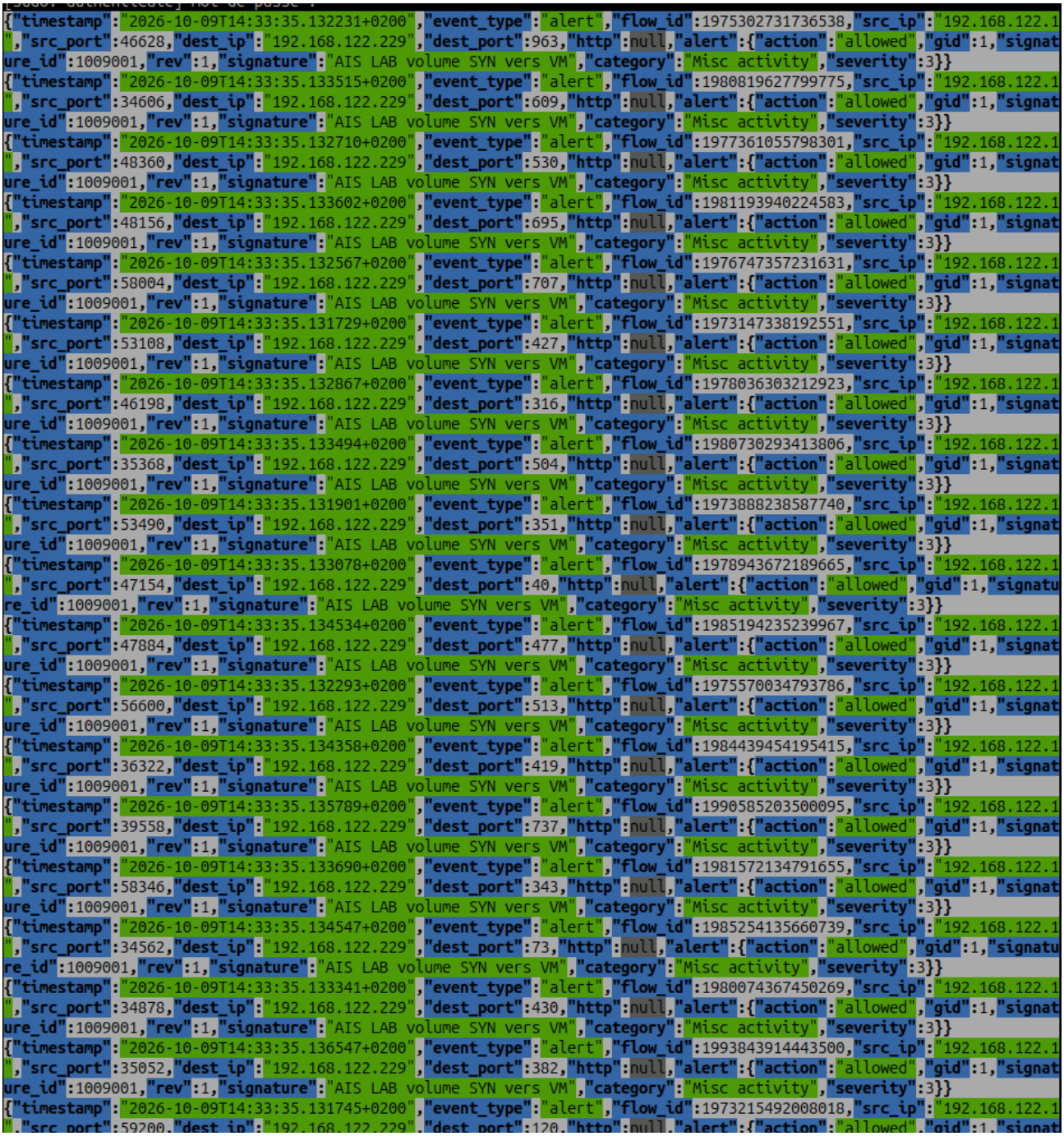
# 7. Pièce illustrée : scénario depuis l’hôte




**P1 — Capture du 9 octobre, 14:37:56.** Début à 14:33:13, scans et codes HTTP de la phase d’exploration visibles. Les noms de services Nmap ne constituent pas une identification de version.

La capture montre le début de la phase répétée, mais pas sa fin ni les douze codes HTTP. Le comptage de 22 GET et les 12 répétitions proviennent de l’extrait EVE complet fourni ; fin 14:35:38 issue de la sortie texte transmise.

# 8. Pièce illustrée : alerte Suricata

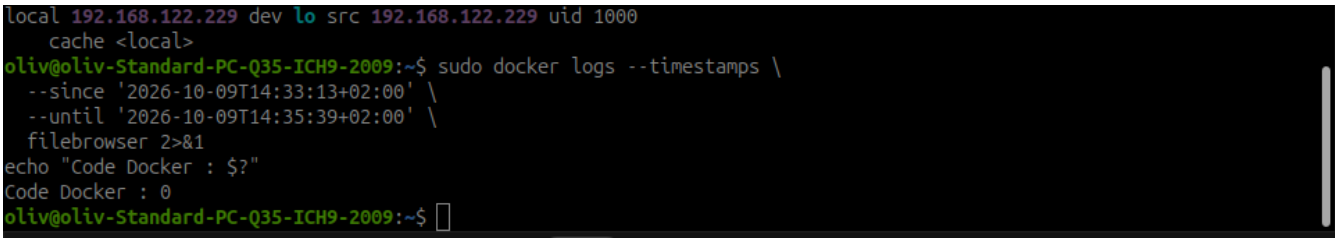



**P2 — Capture du 9 octobre, 14:37:48.** Exemple d'alertes de 14:33:35 : origine 192.168.122.1, destination VM, ports variés, SID 1009001 « AIS LAB volume SYN vers VM », action allowed.

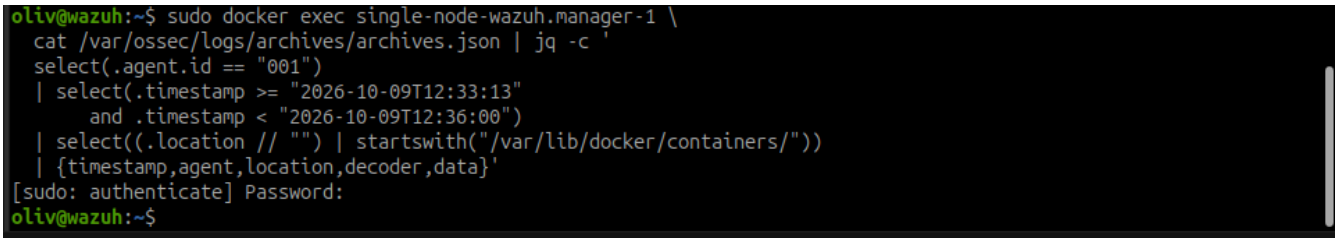
Le total de 99 objets repose sur la sortie texte complète analysée, pas sur le seul nombre de lignes visibles. Cette règle détecte un volume SYN ; elle ne détermine pas l'intention et ne prouve pas un blocage.

# 9. Pièce illustrée et traçabilité des preuves

VM File Browser — logs Docker




Manager Wazuh — sélection des archives




**P3 — Capture du 9 octobre, 14:41:37.** Docker sans message du 14:33:13 au 14:35:39 CEST, code 0 ; sélection Wazuh agent 001 / logs Docker sans objet du 12:33:13 au 12:36:00 UTC. La route locale de la VM apparaît également.

Limite : ces résultats vides ne réfutent pas les requêtes EVE. Ils ne prouvent ni une recherche exhaustive ni la défaillance de Wazuh. Auditd ne retrouve pas d'événement dans la fenêtre de reproduction après correction du format de date.

## Dossier documentaire de référence

**incident-premiers-elements.md** — J9 : sorties, EVE, script, fenêtres et captures.

**completer-chronologie.md** — J10 : journald/auditd, quatre captures, corrélations.

**qualifier-situation.md** — J10 : conclusions établies/probables/non démontrées.

**decider-traitement.md** — J10 : décisions, impacts et vérifications.

**compte-rendu-incident.md** — J10 : compte-rendu et complément REX.

**realiser-rex.md** — J10 : comparaison, causes et améliorations.

Emplacement : docs/securisation-avancee-infrastructures/it-9/ pour la première référence ; it-10/ pour les autres. Captures : docs/assets/img/securisation-avancee-infrastructures/it-9/ et it-10/. Les pièces sont fournies par Olivier ; aucun export complet indépendant des journaux n'est certifié.

## État à la remise

**Investigation et REX documentés ; compromission non démontrée ; améliorations proposées, non déployées.** La comparaison utilise la copie du script fournie. Si le formateur présente une variante ou des traces supplémentaires, réviser le REX en conservant la version antérieure. Aucune résolution d'un incident réel n'est déclarée.